The wedding of

Addie and Dennis

Active Directory & the Domain Name System

A Match Made in Heck

Who are we?

Jim Sykora

- Long time IT generalist
- Security Consultant in Identity Security
- Joined Trimarc early 2022
- Relatively Twitter famous: @JimSycurity



Who are we?

Jake Hildreth

- Long time IT generalist
- Active Directory Security Assessment Service Lead
- Joined Trimarc mid-2021
- Trimarc Twitch Happy Hour Co-host
- Maintainer of Locksmith
- Relatively Mastodon famous: @horse@infosec.exchange



Who is Dennis?

Domain Name System (DNS)

- Born in the early 80s
- Essential to the modern internet
- Provides recursive name resolution
- It’s ALWAYS DNS



Who is Addie?

Active Directory (AD)

- Kerberos
- Lightweight Directory Access Protocol
- Federation
- Certificate Services



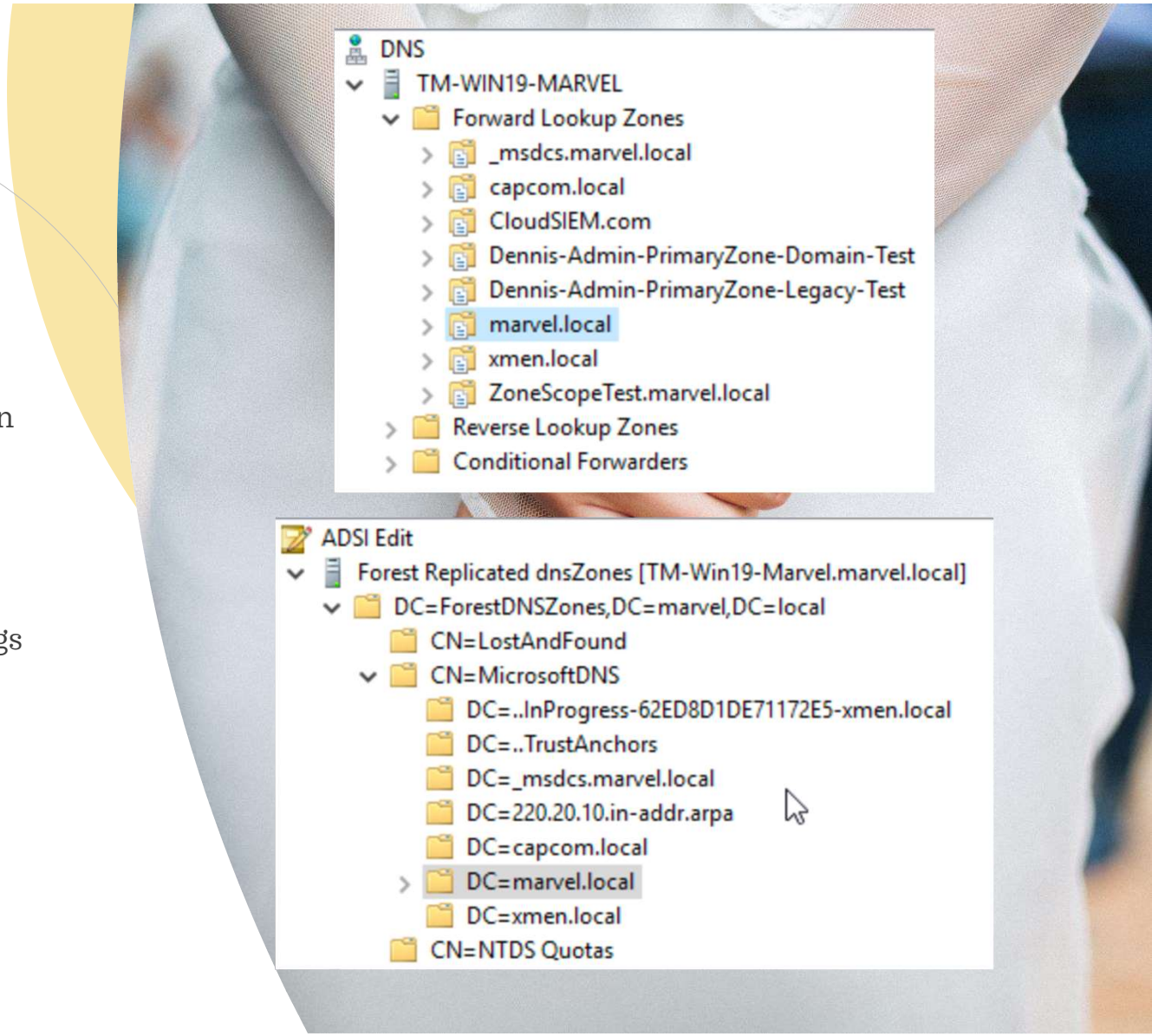
A Quick History

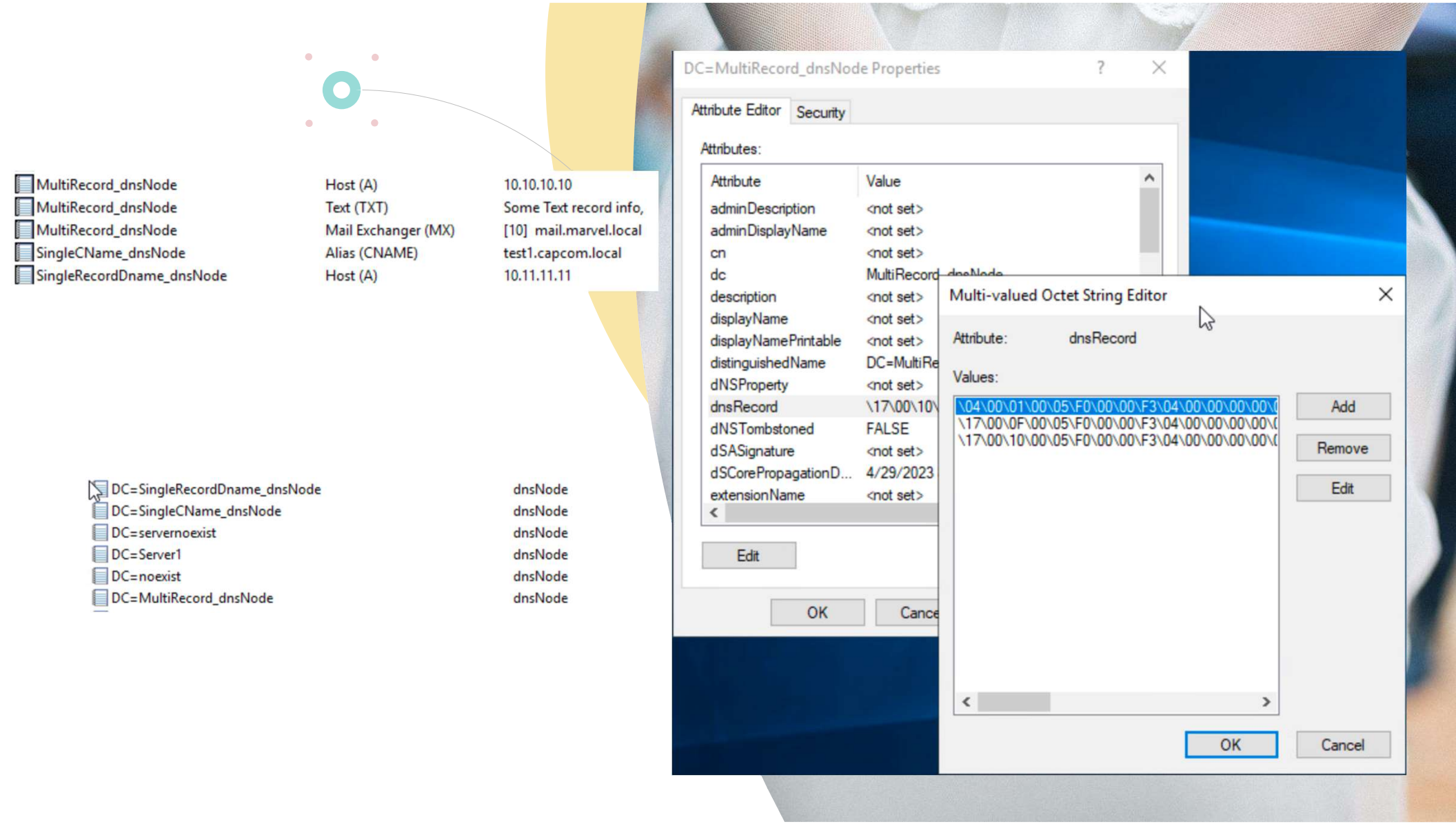
- Pre-Windows 2000 name resolution was a mess
- February 17, 2000: Windows 2000 family is released
- AD + DNS = ♥ ♥ ♥
- AD uses DNS for almost all the things
- DNS info is stored in AD
- Compromise AD to compromise DNS
- Compromise DNS to compromise AD



A Quick History

- Pre-Windows 2000 name resolution was a mess
- February 17, 2000: Windows 2000 family is released
- AD + DNS = ♥♥♥
- AD uses DNS for almost all the things
- DNS info is stored in AD
- Compromise AD to compromise DNS
- Compromise DNS to compromise AD




MultiRecord_dnsNode Host (A) 10.10.10.10
MultiRecord_dnsNode Text (TXT) Some Text record info,
MultiRecord_dnsNode Mail Exchanger (MX) [10] mail.marvel.local
SingleCName_dnsNode Alias (CNAME) test1.capcom.local
SingleRecordDname_dnsNode Host (A) 10.11.11.11
DC=SingleRecordDname_dnsNode dnsNode
DC=SingleCName_dnsNode dnsNode
DC=servernoexist dnsNode
DC=Server1 dnsNode
DC=noexist dnsNode
DC=MultiRecord_dnsNode dnsNode
DC=MultiRecord_dnsNode Properties
Attribute Editor
Security
Attributes:
Attribute
Value
adminDescription <not set>
adminDisplayName <not set>
cn <not set>
dc MultiRecord_dnsNode
description <not set>
displayName <not set>
displayNamePrintable <not set>
distinguishedName DC=MultiRe
dNSProperty <not set>
dnsRecord \17\00\10\
dNSTombstoned FALSE
dSASignature <not set>
dSCorePropagationD... 4/29/2023
extensionName <not set>
Edit
OK
Cance
Multi-valued Octet String Editor
Attribute: dnsRecord
Values:
\04\00\01\00\05\F0\00\00\F3\04\00\00\00\00\
\17\00\0F\00\05\F0\00\00\F3\04\00\00\00\00\
\17\00\10\00\05\F0\00\00\F3\04\00\00\00\00\
Add
Remove
Edit
OK
Cancel

A Happy Marriage

- Something Old
- Something New
- Something Borrowed
- Something Blue



The wedding of

Addie

and

Dennis

Something Old

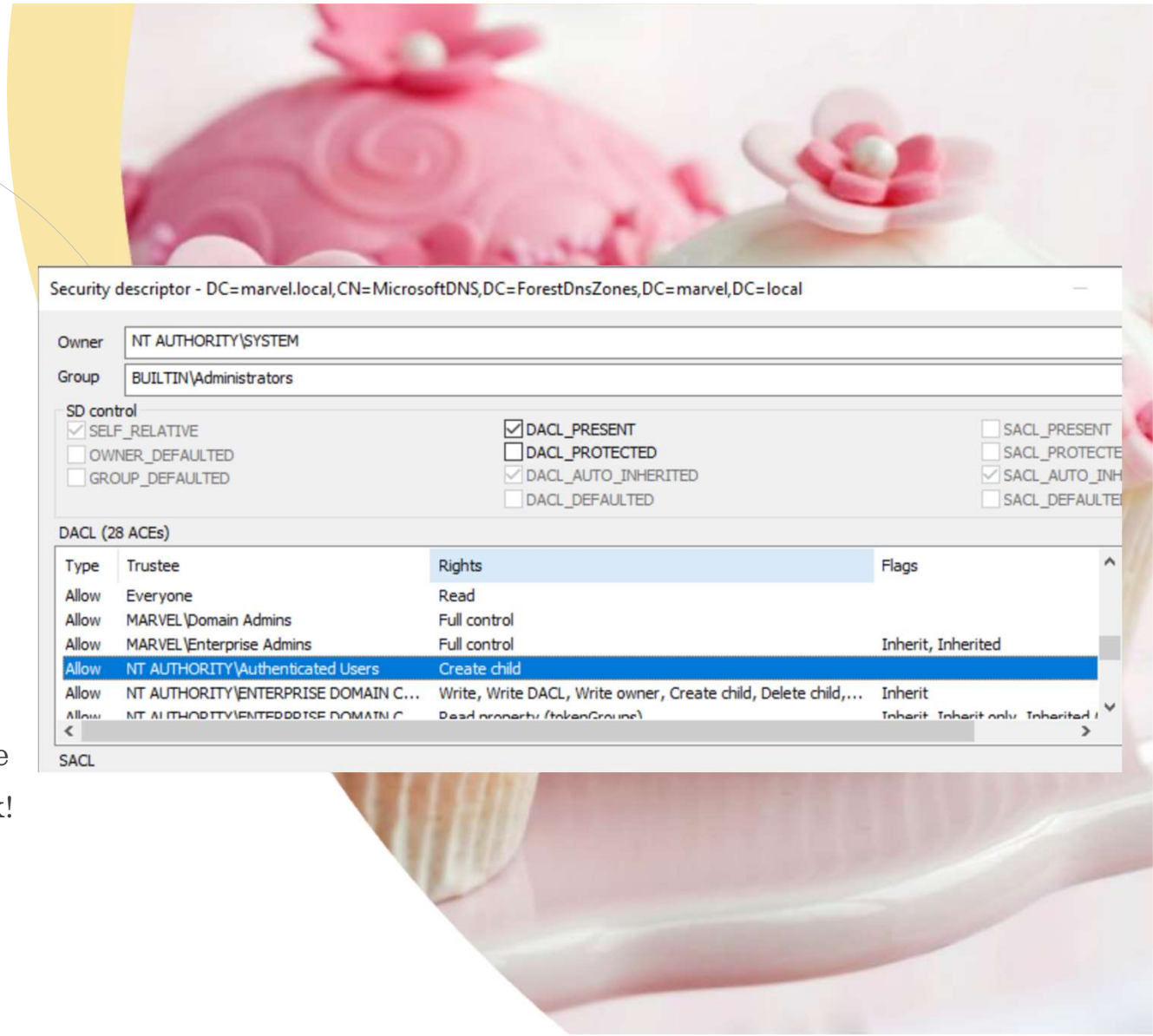
Kevin Robertson: Powermad

- Takes advantage of default user rights to create DNS records (dnsNodes in AD)
- */WPAD/tombstoned computers
- Redirect traffic to attacker machine
- Responder… but more likely to work!



Kevin Robertson: Powermad

- Takes advantage of default user rights to create DNS records (dnsNodes in AD)
- */WPAD/tombstoned computers
- Redirect traffic to attacker machine
- Responder… but more likely to work!



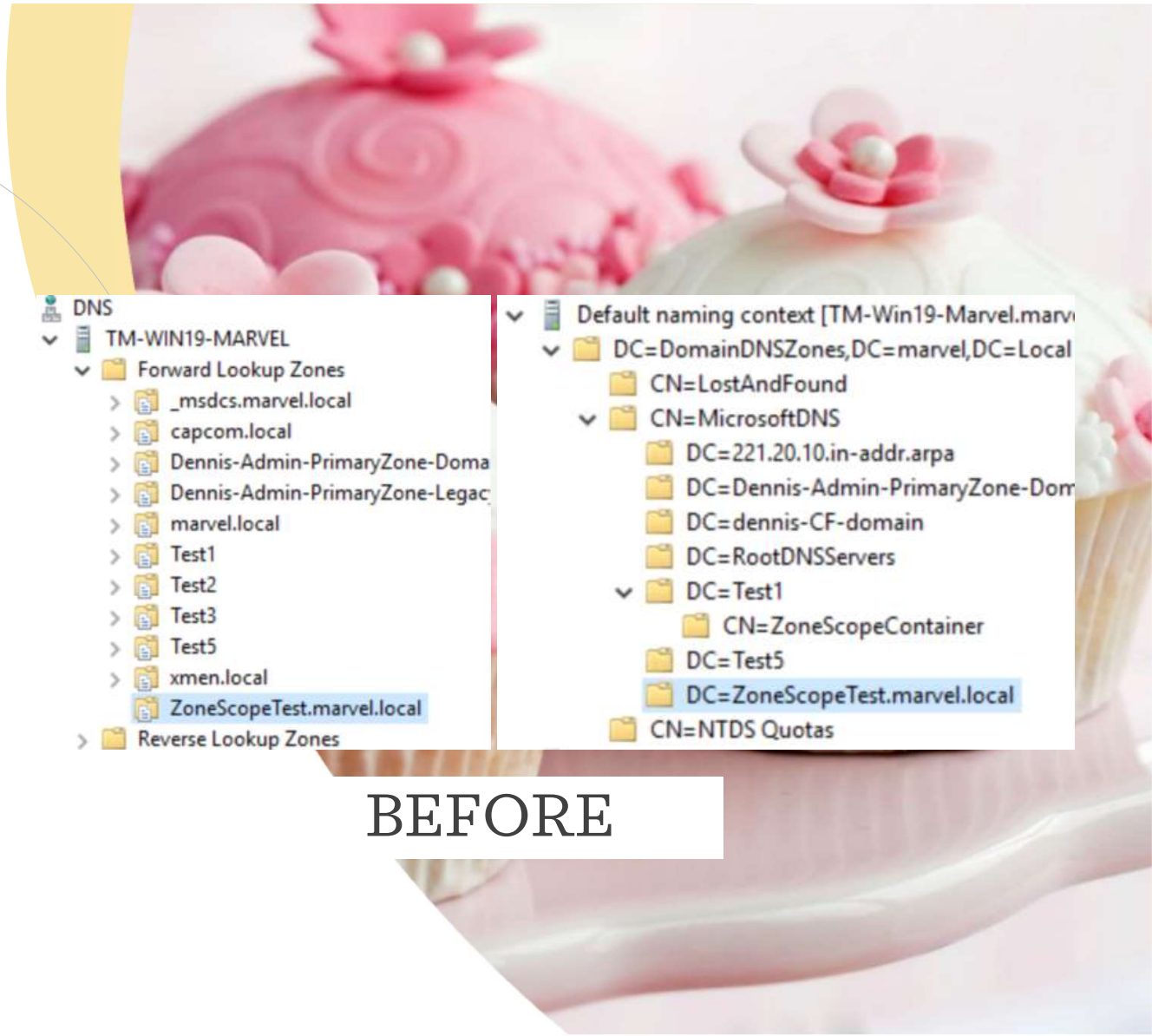
Kevin Robertson: Powermad

- Default user rights also allow creating Zone Scope Containers.
- ...and Zone Scopes
- ...and dnsNodes
- New-ADIDNSZoneScope



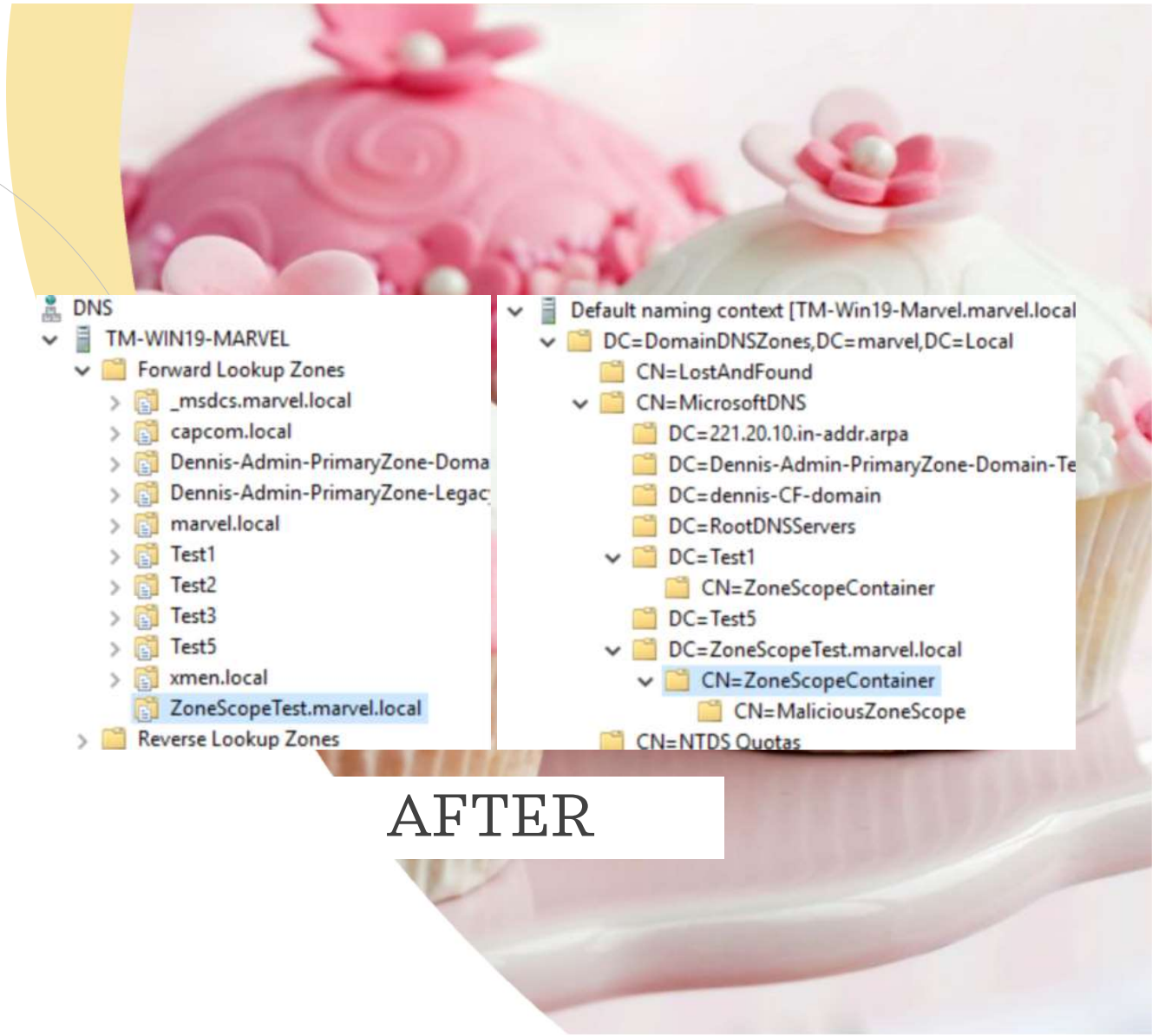
Kevin Robertson: Powermad

- Default user rights also allow creating Zone Scope Containers.
- ...and Zone Scopes
- ...and dnsNodes
- New-ADIDNSZoneScope



Kevin Robertson: Powermad

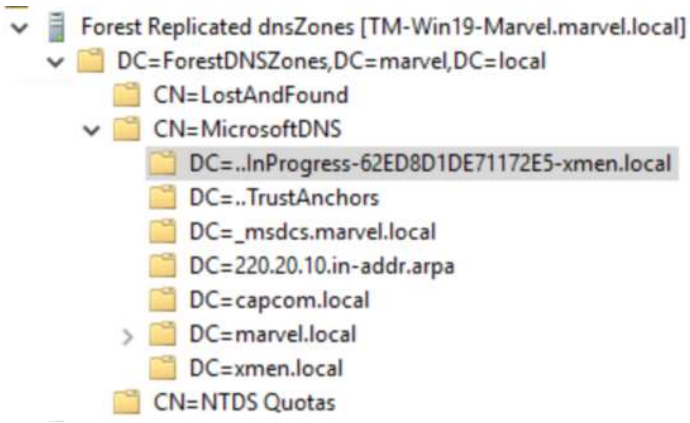
- Default user rights also allow creating Zone Scope Containers.
- …and Zone Scopes
- …and dnsNodes
- New-ADIDNSZoneScope



Dirk-jan Mollema & Elad Shamir: DACL Abuse

- ”Relaying” Kerberos
- Resource-Based Constrained Delegation (RBCD)
- ms-DS-Additional-Dns-Host-Name attribute
- ms-DS-AllowedToActOnBehalfOfOtherIdentity
- Vulnerable DACLs on dnsNodes & dnsZones





Forest Zones

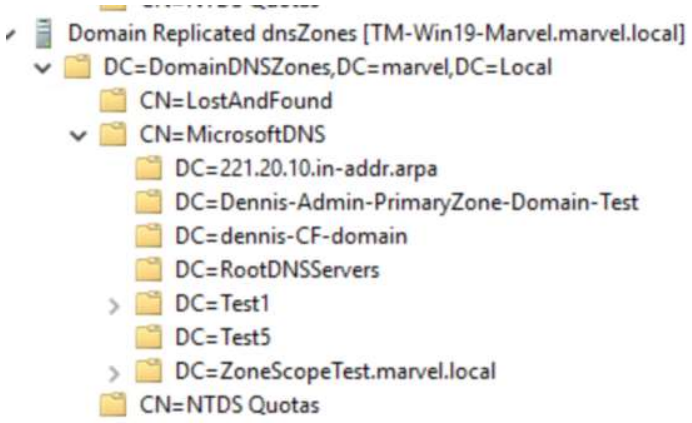
Owner: SYSTEM Change

Permissions | Auditing | Effective Access

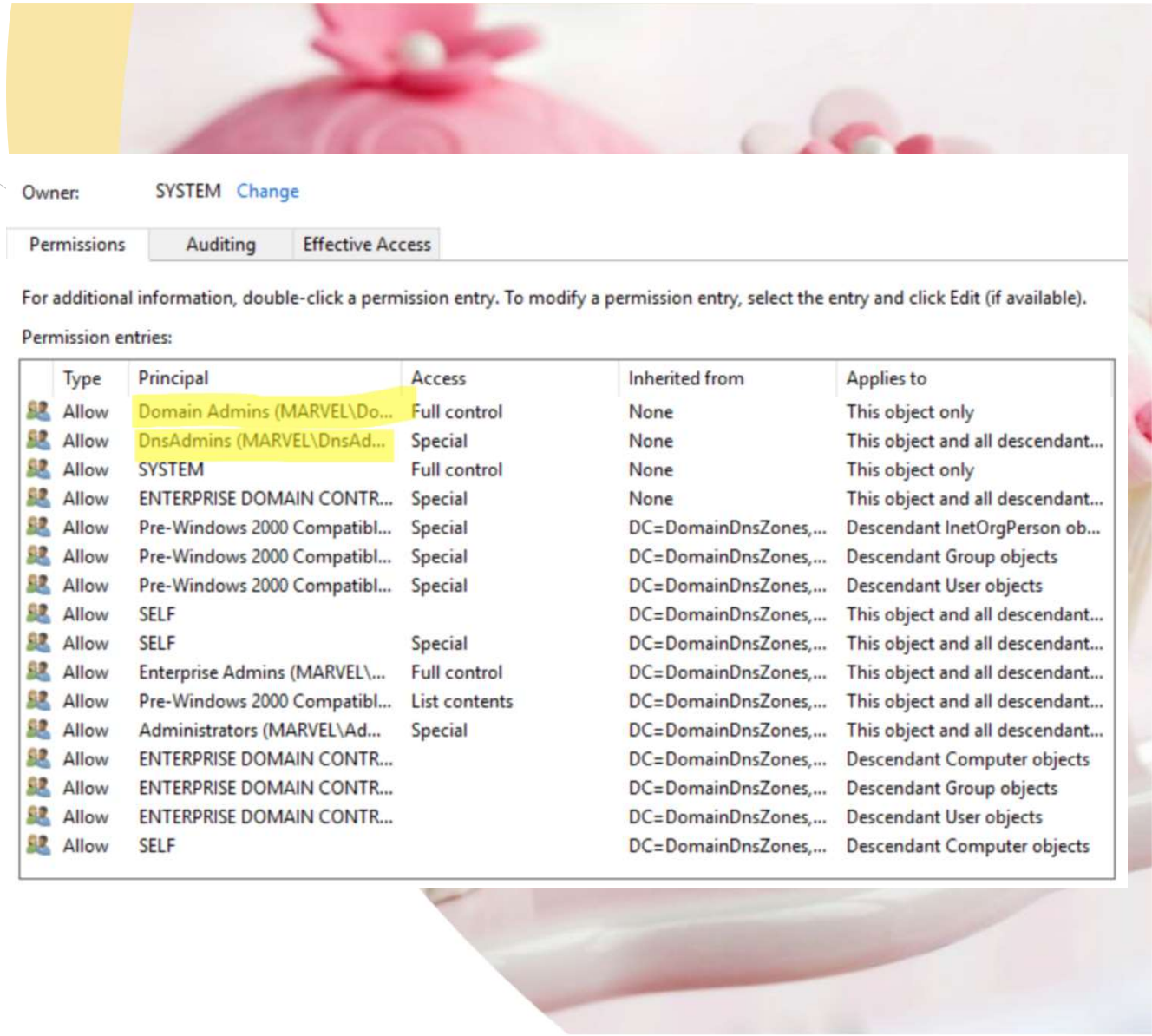
For additional information, double-click a permission entry. To modify a permission entry, select the entry and click Edit (if available).

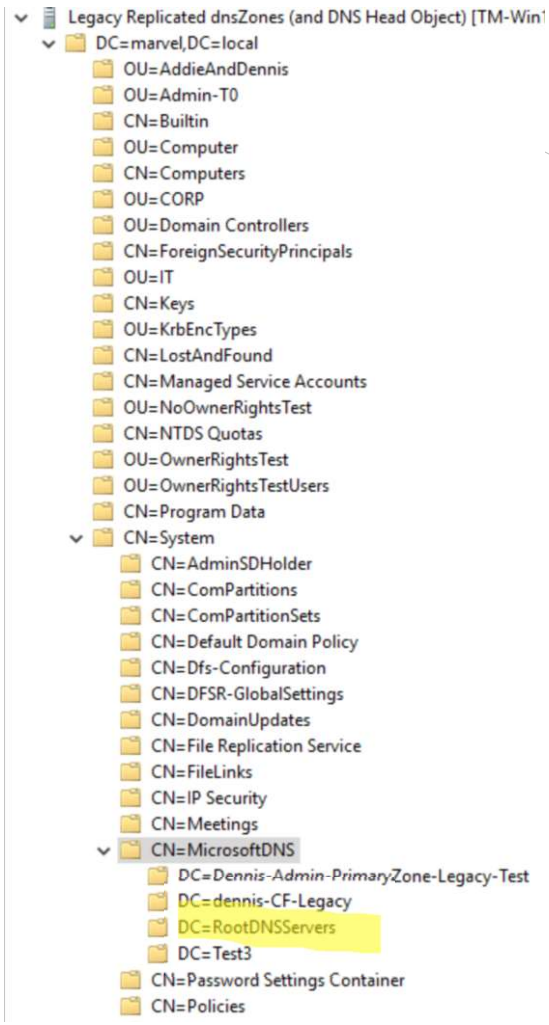
Permission entries:

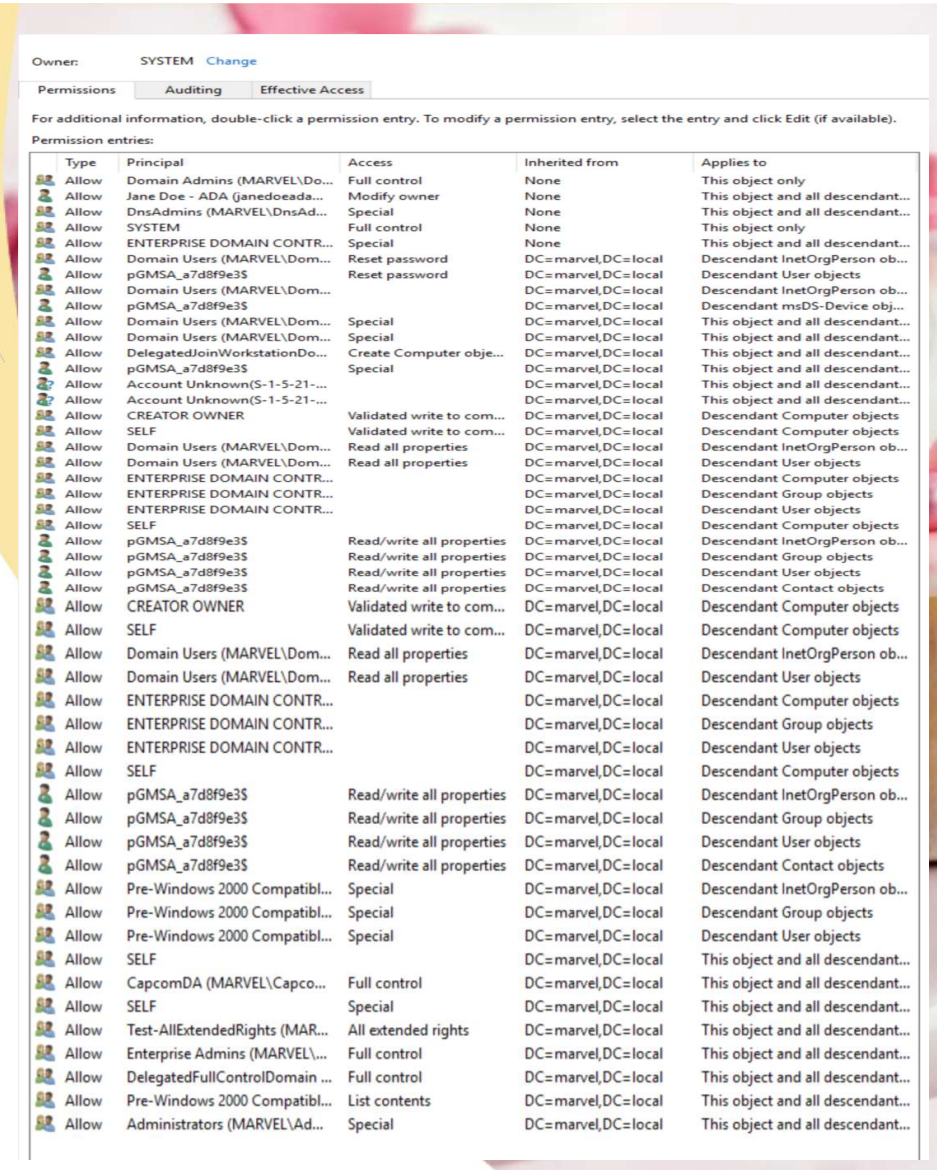
Type	Principal	Access	Inherited from	Applies to
Allow	SYSTEM	Full control	None	This object only
Allow	ENTERPRISE DOMAIN CONTR...	Special	None	This object and all descendant ...
Allow	Pre-Windows 2000 Compatible...	Special	DC=ForestDnsZones,DC...	Descendant InetOrgPerson obje...
Allow	Pre-Windows 2000 Compatible...	Special	DC=ForestDnsZones,DC...	Descendant Group objects
Allow	Pre-Windows 2000 Compatible...	Special	DC=ForestDnsZones,DC...	Descendant User objects
Allow	SELF		DC=ForestDnsZones,DC...	This object and all descendant ...
Allow	SELF	Special	DC=ForestDnsZones,DC...	This object and all descendant ...
Allow	Enterprise Admins (MARVEL\E...	Full control	DC=ForestDnsZones,DC...	This object and all descendant ...
Allow	Pre-Windows 2000 Compatible...	List contents	DC=ForestDnsZones,DC...	This object and all descendant ...
Allow	Administrators (MARVEL\Admi...	Special	DC=ForestDnsZones,DC...	This object and all descendant ...
Allow	ENTERPRISE DOMAIN CONTR...		DC=ForestDnsZones,DC...	Descendant Computer objects
Allow	ENTERPRISE DOMAIN CONTR...		DC=ForestDnsZones,DC...	Descendant Group objects
Allow	ENTERPRISE DOMAIN CONTR...		DC=ForestDnsZones,DC...	Descendant User objects
Allow	SELF		DC=ForestDnsZones,DC...	Descendant Computer objects



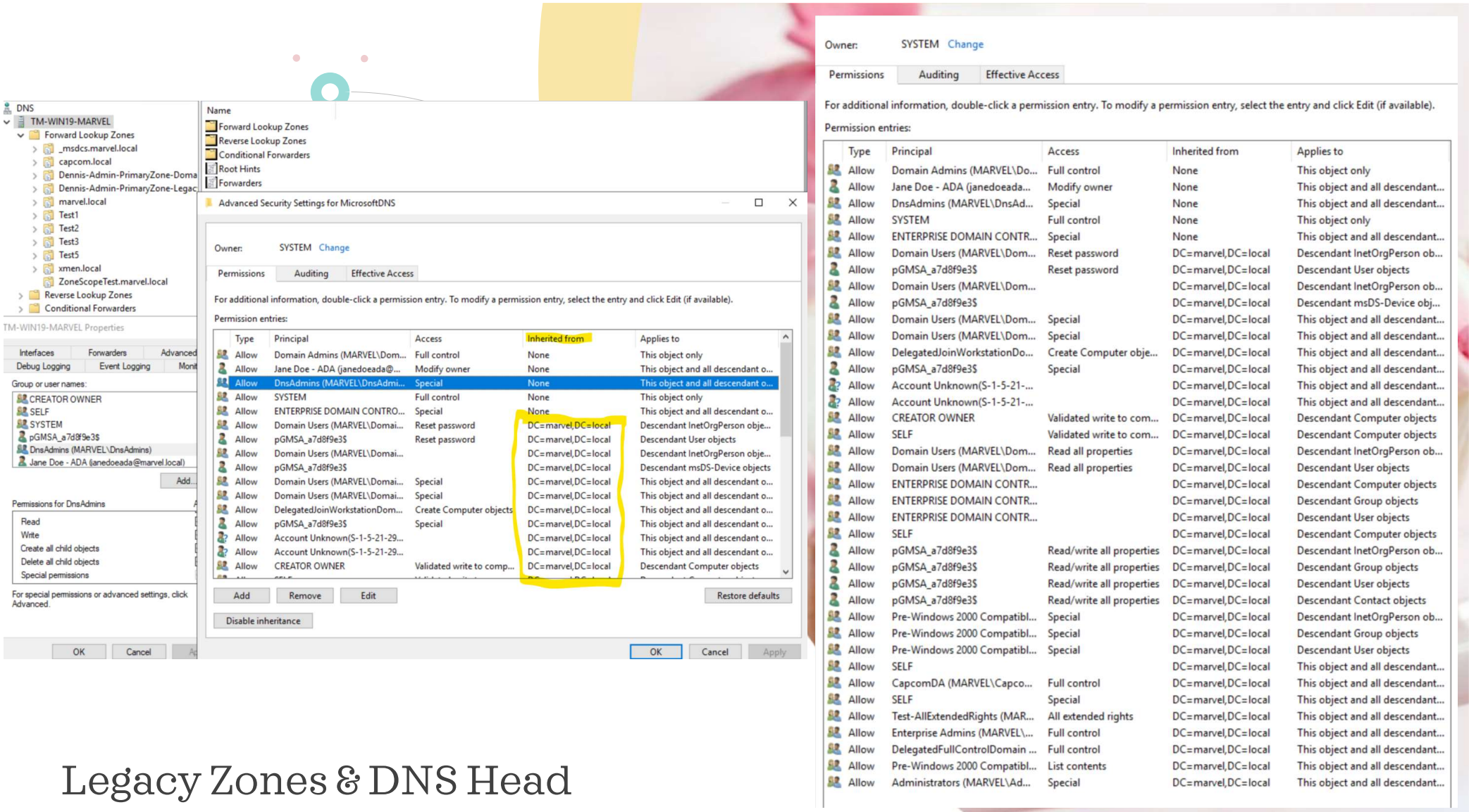
Domain Zones







Legacy Zones & DNS Head

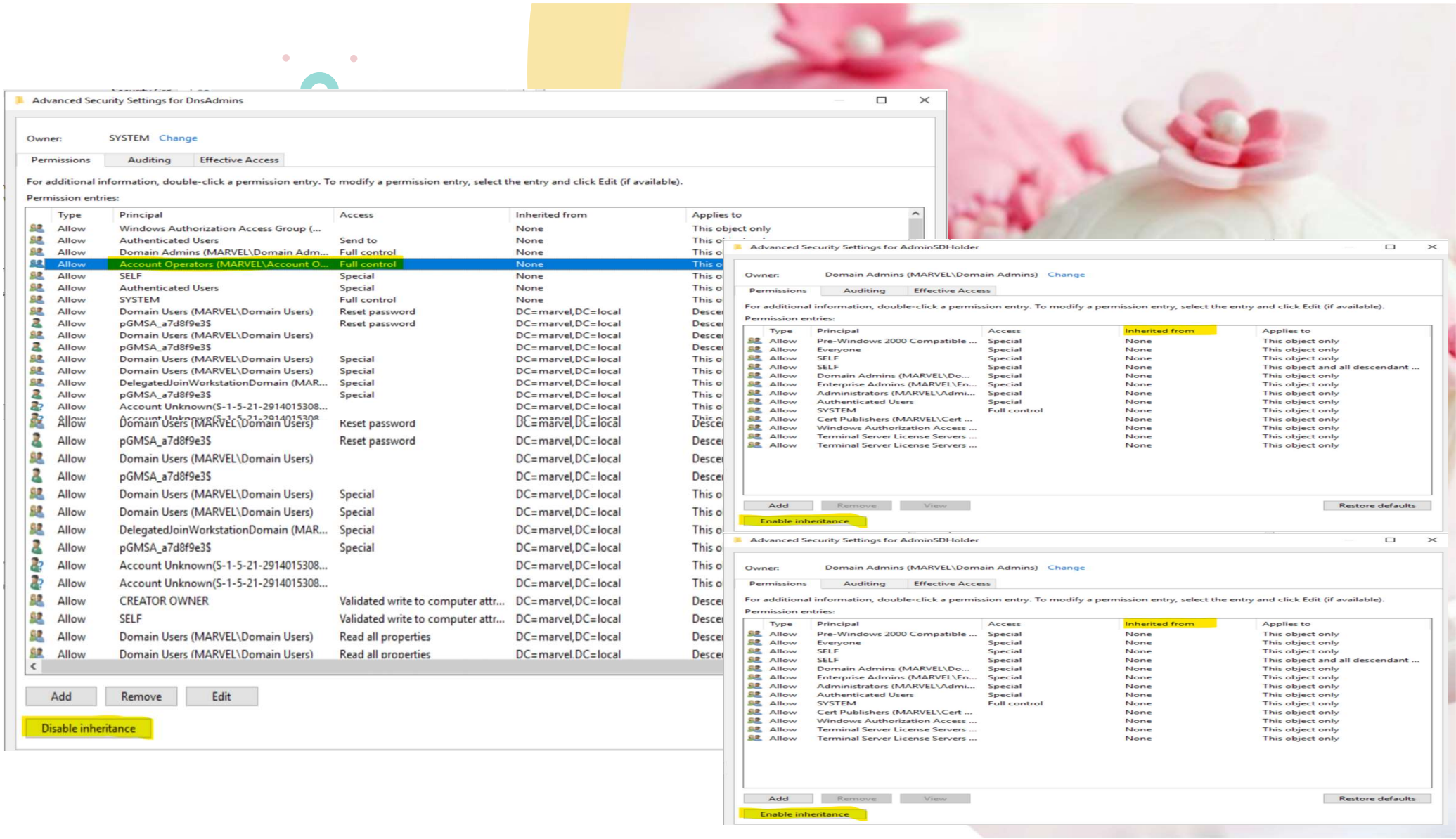


Legacy Zones & DNS Head

Shay Ber: DnsAdmins

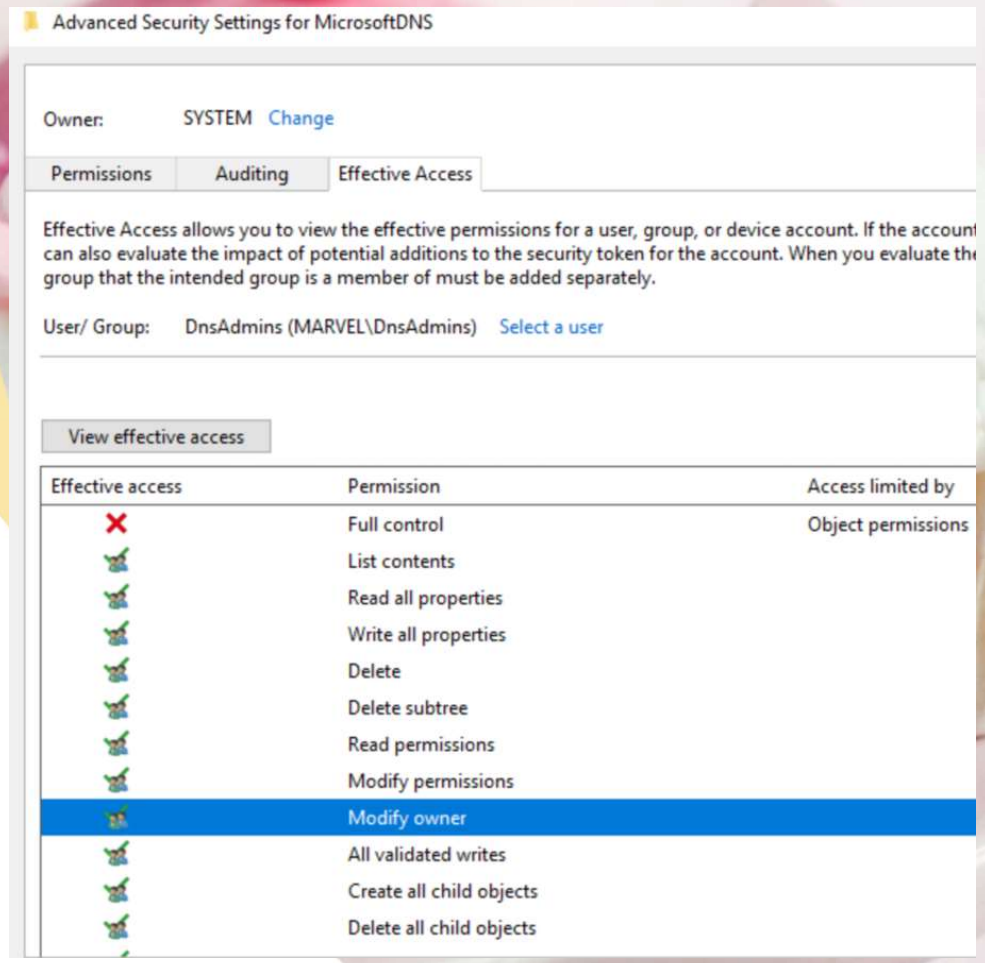
- (Were) able to replace DLLs on DNS Servers aka DCs in most environments
- Reported in 2017, not resolved until 2021! (and then only Server 2012+)
- Safe now...?
- Not protected by SDProp+AdminSDHolder
- Many paths to attack




Advanced Security Settings for DnsAdmins
Owner: SYSTEM Change
Permissions Auditing Effective Access
For additional information, double-click a permission entry. To modify a permission entry, select the entry and click Edit (if available).
Permission entries:
Type Principal Access Inherited from Applies to
Allow Windows Authorization Access Group (... None This object only
Allow Authenticated Users Send to None
Allow Domain Admins (MARVEL\Domain Adm... Full control None
Allow Account Operators (MARVEL\Account O... Full control None
Allow SELF Special None
Allow Authenticated Users Special None
Allow SYSTEM Full control None
Allow Domain Users (MARVEL\Domain Users) Reset password DC=marvel,DC=local
Allow pGMSA_a7d8f9e3$ Reset password DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) DC=marvel,DC=local
Allow pGMSA_a7d8f9e3$ DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) Special DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) Special DC=marvel,DC=local
Allow DelegatedJoinWorkstationDomain (MAR... Special DC=marvel,DC=local
Allow pGMSA_a7d8f9e3$ Special DC=marvel,DC=local
Allow Account Unknown(S-1-5-21-2914015308... DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) Reset password DC=marvel,DC=local
Allow pGMSA_a7d8f9e3$ Reset password DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) DC=marvel,DC=local
Allow pGMSA_a7d8f9e3$ DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) Special DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) Special DC=marvel,DC=local
Allow DelegatedJoinWorkstationDomain (MAR... Special DC=marvel,DC=local
Allow pGMSA_a7d8f9e3$ Special DC=marvel,DC=local
Allow Account Unknown(S-1-5-21-2914015308... DC=marvel,DC=local
Allow Account Unknown(S-1-5-21-2914015308... DC=marvel,DC=local
Allow CREATOR OWNER Validated write to computer attr... DC=marvel,DC=local
Allow SELF Validated write to computer attr... DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) Read all properties DC=marvel,DC=local
Allow Domain Users (MARVEL\Domain Users) Read all properties DC=marvel,DC=local
Add Remove Edit
Disable inheritance
Advanced Security Settings for AdminSDHolder
Owner: Domain Admins (MARVEL\Domain Admins) Change
Permissions Auditing Effective Access
For additional information, double-click a permission entry. To modify a permission entry, select the entry and click Edit (if available).
Permission entries:
Type Principal Access Inherited from Applies to
Allow Pre-Windows 2000 Compatible ... Special None This object only
Allow Everyone Special None This object only
Allow SELF Special None This object only
Allow SELF Special None This object and all descendant ...
Allow Domain Admins (MARVEL\Do... Special None This object only
Allow Enterprise Admins (MARVEL\En... Special None This object only
Allow Administrators (MARVEL\Admi... Special None This object only
Allow Authenticated Users Special None This object only
Allow SYSTEM Full control None This object only
Allow Cert Publishers (MARVEL\Cert ... None This object only
Allow Windows Authorization Access ... None This object only
Allow Terminal Server License Servers ... None This object only
Allow Terminal Server License Servers ... None This object only
Add Remove View Restore defaults
Enable inheritance
Advanced Security Settings for AdminSDHolder
Owner: Domain Admins (MARVEL\Domain Admins) Change
Permissions Auditing Effective Access
For additional information, double-click a permission entry. To modify a permission entry, select the entry and click Edit (if available).
Permission entries:
Type Principal Access Inherited from Applies to
Allow Pre-Windows 2000 Compatible ... Special None This object only
Allow Everyone Special None This object only
Allow SELF Special None This object only
Allow SELF Special None This object and all descendant ...
Allow Domain Admins (MARVEL\Do... Special None This object only
Allow Enterprise Admins (MARVEL\En... Special None This object only
Allow Administrators (MARVEL\Admi... Special None This object only
Allow Authenticated Users Special None This object only
Allow SYSTEM Full control None This object only
Allow Cert Publishers (MARVEL\Cert ... None This object only
Allow Windows Authorization Access ... None This object only
Allow Terminal Server License Servers ... None This object only
Allow Terminal Server License Servers ... None This object only
Add Remove View Restore defaults
Enable inheritance

Shay Ber: DnsAdmins

- Able to replace DLLs on DNS Servers aka DCs in most environments
- Reported in 2017, not resolved until 2021! (and then only Server 2012+)
- Safe now...?
- Not protected by SDProp+AdminSDHolder
- Many paths to attack



The wedding of

Addie

and

Dennis

Something New

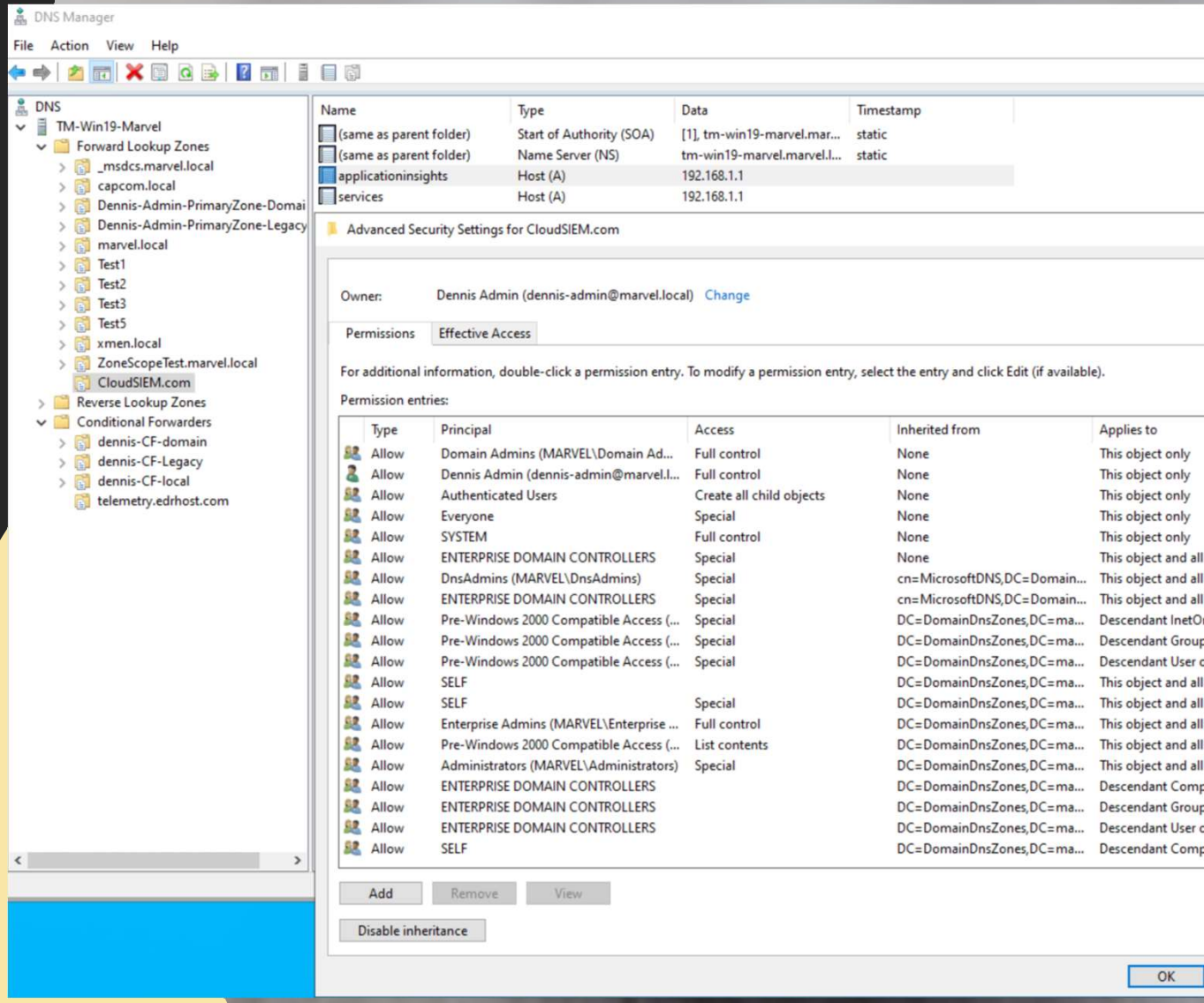
Evil Sinkhole

- Create new DNS Zones
  - DomainDNSZones
  - Legacy Zones
  - Local Zones (not replicated)
- Create new Conditional Forwarder
- Send traffic to:
  - Attacker-controlled DNS
  - Attacker-controlled device
  - Nothing



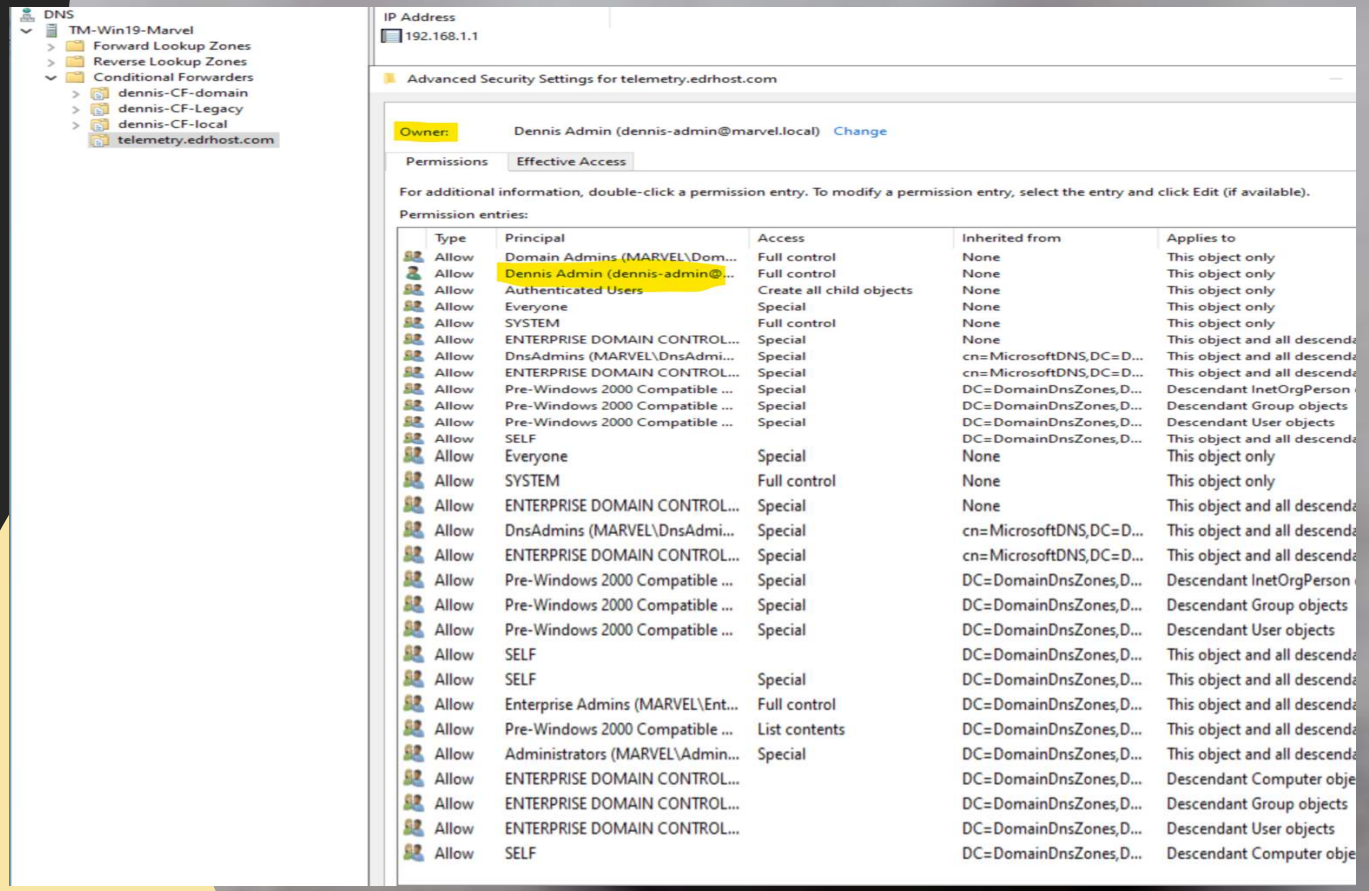
Evil Sinkhole

- Create new DNS Zones
  - DomainDNSZones
  - Legacy Zones
  - Local Zones (not replicated)
- Create new Conditional Forwarders
- Send traffic to:
  - Attacker-controlled DNS
  - Attacker-controlled device
  - Nothing



Evil Sinkhole

- Create new DNS Zones
  - DomainDNSZones
  - Legacy Zones
  - Local Zones (not replicated)
- Create new Conditional Forwarders
- Send traffic to:
  - Attacker-controlled DNS
  - Attacker-controlled device
  - Nothing



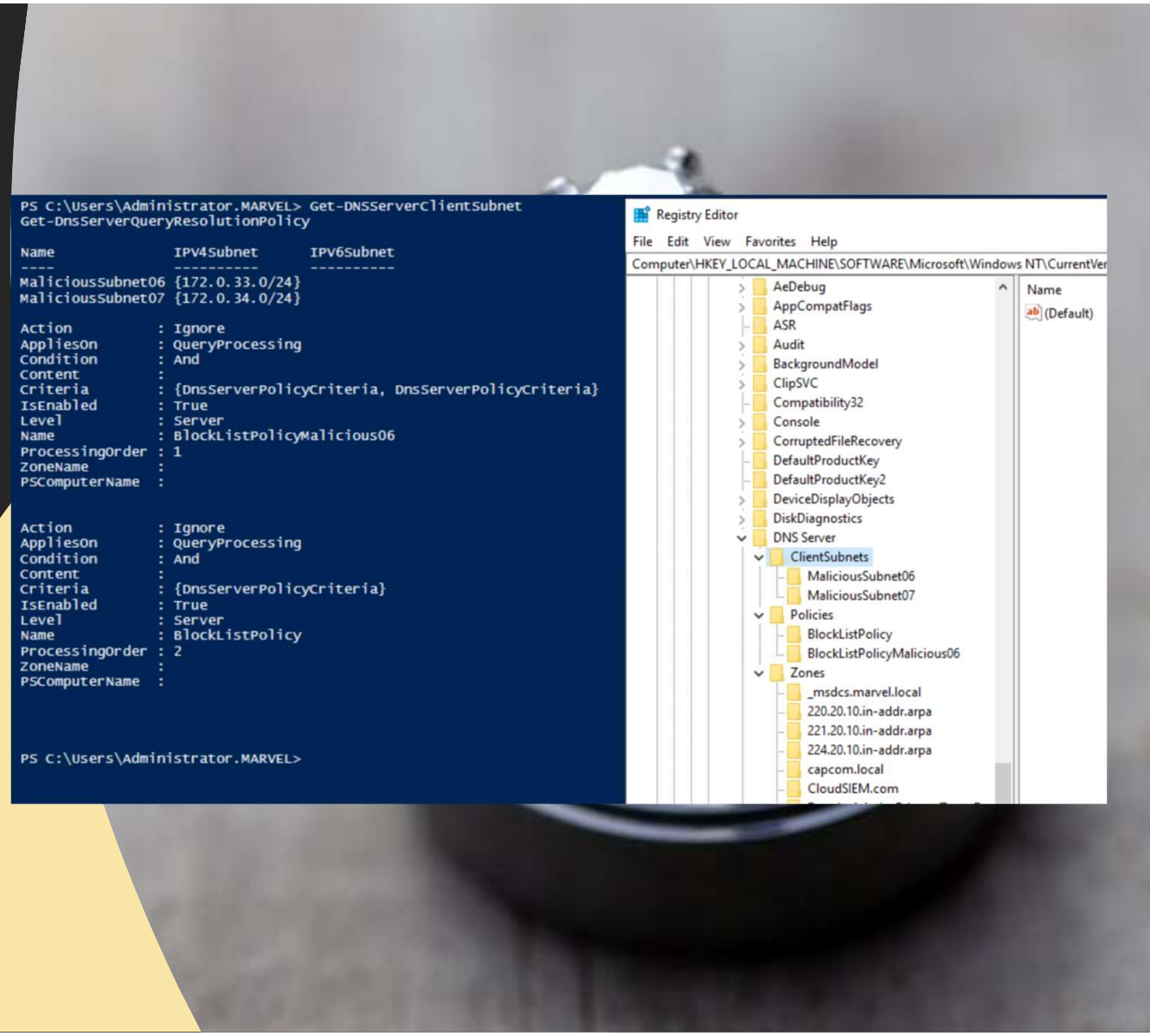
Evil Sinkhole Uses

- Blind your EDR
- Blind your SIEM
- Redirect management traffic
- Redirect patching traffic
- Redirect AV signatures
- Redirect Trusted Sites or Intranet Zone?
- Fairly noisy & wide-ranging



Policy Poisoning

- Introduced in Windows Server 2016
- 2 types: Query Resolution & Recursion
- Don't show up in DNS GUI
- Stored in the registry of the DNS server
- Similar use cases to Evil Sinkhole... but slightly more evil by being more *sneaky*



Dangling SPNs

- Kerberos relies on Hostnames
- Service Principal Names (SPNs) are often added, rarely removed
- SPN form: SERVICE/HOST
- Find accounts with SPNs pointing to hosts that no longer exist
- Scan AD for SPNs with hosts that no longer exist
- Create new computer account and/or dnsNode for missing host
- Coerce authentication
- Profit?



Dangling SPNs

- Kerberos relies on Hostnames
- Service Principal Names (SPNs) are often added, rarely removed
- SPN form: SERVICE/HOST
- Find accounts with SPNs pointing to hosts that no longer exist
- Scan AD for SPNs with hosts that no longer exist
- Create new computer account and/or dnsNode for missing host
- Coerce authentication
- Profit?



The wedding of

Addie

and

Dennis

Something Borrowed

Defenses: Configuration

- Disable LLMNR/NBNS/mDNS
- Create wildcard (*) record
- Create WPAD TXT record
- Empty DnsAdmins
- Eliminate Legacy Zones
- Audit Global Query Block List (GQBL)



Defenses: Auditing

- Use DHCP Dynamic Update service account
- Audit DNS DACLs
- Audit DNS Zones
- Audit Zone Scopes
- Audit Policies
- Audit Dangling SPNs



The wedding of

Addie

and

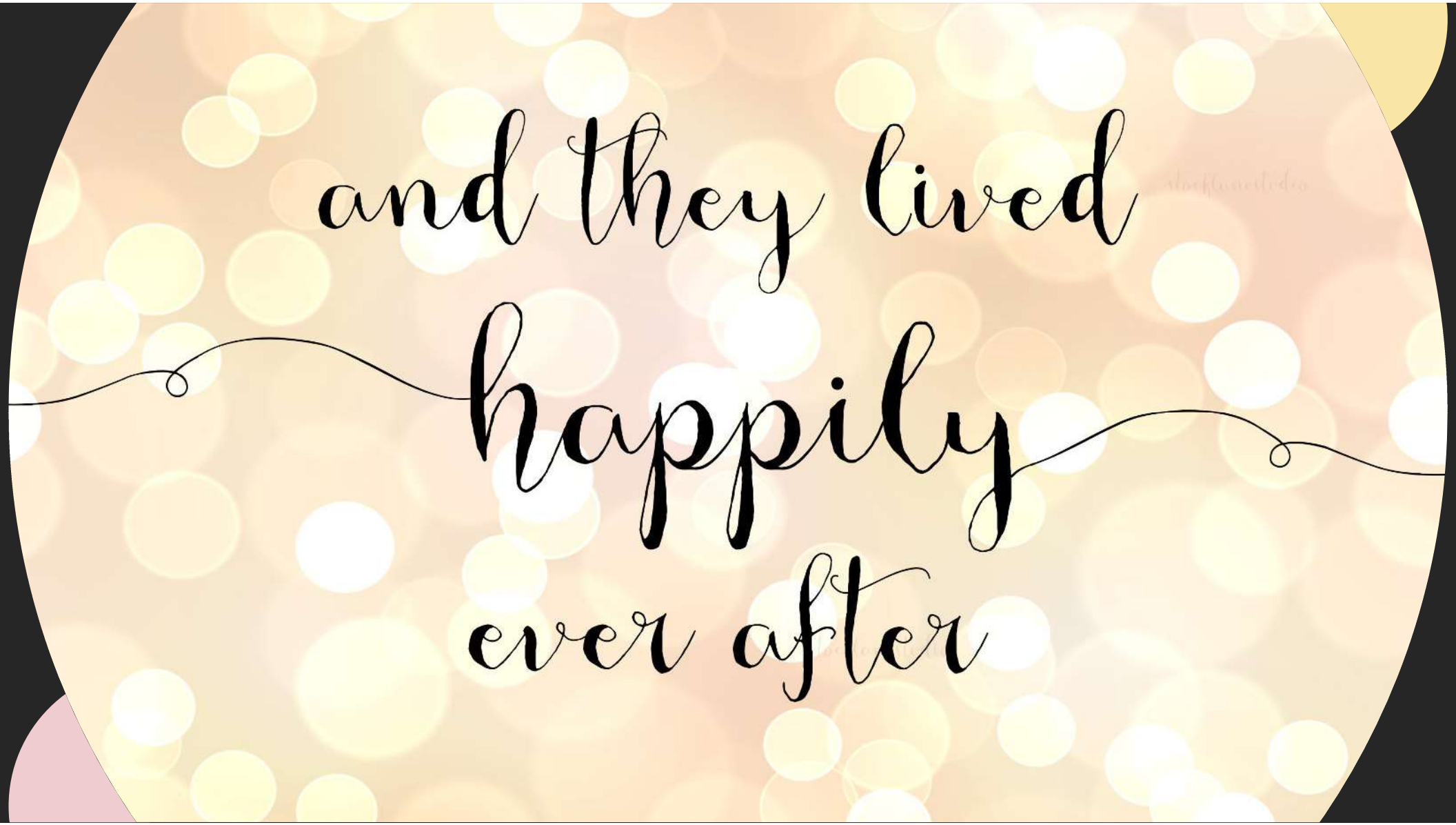
Dennis

Something Blue

BlueTuxedo

- Dangling SPNs
- DnsAdmins Membership
- Wildcard Record
- WPAD Record
- Global Query Block List (GQBL)
- DHCP Dynamic Update service account
- Weird DACLs
- Tombstoned DNS Records
- Conditional Forwarder Auditing
- Zone & Zone Scope Auditing
- Forwarder Configuration
- Socket Pool Configuration




and they lived
happily
ever after

Thank you!

Kevin Robertson
Shay Ber
Charlie Clark
Dirk-jan Mollema
Elad Shamir

BSidesCharm
Trimarc
You



It's not DNS
There's no way it's DNS
It was DNS

The wedding of

Jim and Jake

Questions?

Jim Sykora
@JimSycurity

Jake Hildreth
@horse@infosec.exchange

Resources

adsecurity.org/?p=4056

adsecurity.org/?p=4064

blog.0patch.com/2021/11/micropatch-for-remote-code-execution-by.html

dirkjanm.io/abusing-forgotten-permissions-on-precreated-computer-objects-in-active-directory/

dirkjanm.io/krbrelayx-unconstrained-delegation-abuse-toolkit/

dirkjanm.io/relaying-kerberos-over-dns-with-krbrelayx-and-mitm6/

exploit.ph/user-constrained-delegation.html

github.com/blackc03r/OSCP-Cheatsheets/blob/master/offensive-security-experiments/active-directory-kerberos-abuse/from-dnsadmins-to-system-to-domain-compromise.md

github.com/dirkjanm/krbrelayx/

github.com/Kevin-Robertson/Powermad

learn.microsoft.com/en-US/troubleshoot/windows-server/networking/record-cannot-deleted-access-denied

learn.microsoft.com/en-us/windows/win32/adschema/r-dns-host-name-attributes

learn.microsoft.com/en-us/windows/win32/adschema/r-domain-other-parameters

medium.com/@esnesenon/feature-not-bug-dnsadmin-to-dc-compromise-in-one-line-a0f779b8dc83

medium.com/techzap/dns-admin-privesc-in-active-directory-ad-windows-ecc7ed5a21a2

msrc.microsoft.com/update-guide/vulnerability/CVE-2021-40469

phackt.com/dnsadmins-group-exploitation-write-permissions

phackt.com/dnsadmins-group-mitigation

www.labofapenetrationtester.com/2017/05/abusing-dnsadmins-privilege-for-escalation-in-active-directory.html

www.netspi.com/blog/technical/network-penetration-testing/adidns-revisited/

www.netspi.com/blog/technical/network-penetration-testing/exploiting-adidns/

www.netspi.com/blog/technical/network-penetration-testing/machineaccountquota-is-useful-sometimes/

www.netspi.com/blog/technical/network-penetration-testing/machineaccountquota-is-useful-sometimes/

www.semperis.com/blog/dnsadmins-revisited/

www.semperis.com/blog/spn-jacking-an-edge-case-in-writespn-abuse/

www.trustwave.com/en-us/resources/blogs/spiderlabs-blog/introducing-responder-10/